

Matrices de cotation et options de traitement

Le cours de ce matin a posé le processus et son vocabulaire. Il a laissé une question ouverte, celle que la direction posera dès que des risques lui seront présentés : sur quoi le RSSI se fonde-t-il pour dire que celui-ci est plus grave que celui-là, et pourquoi celui-ci mérite un budget quand celui-là attend ? Ce TD répond en construisant l'instrument qui porte cette réponse, la matrice de cotation, puis en s'en servant pour décider. À la fin de la séance, les scénarios bâtis en séance 6 auront tous une place sur une grille, une décision et un responsable.

Objectifs de la séance

À l'issue de ce TD :

- **Expliquer** ce qu'est une matrice de cotation, ce qu'elle calcule et ce qu'elle ne calcule pas
- **Coter** un scénario de risque en gravité et en vraisemblance sur les échelles que le groupe a justifiées en séance 5, sans les redéfinir
- **Placer** une ligne d'acceptation et dire quelle instance a la légitimité de la fixer
- **Choisir** une option de traitement pour chaque risque et défendre ce choix devant un contradicteur
- **Repérer** les trois manipulations classiques par lesquelles une cotation devient un exercice de justification

Prérequis

- Les échelles de gravité G1 à G4 et de vraisemblance V1 à V4 rédigées et justifiées en séance 5, dans le dossier D5. **Elles se reprennent telles quelles.** Recoter avec une échelle neuve rendrait incomparables les risques déjà traités, et c'est exactement ce qu'un auditeur ira vérifier.
- Les scénarios stratégiques et opérationnels construits en séance 6, notamment ceux qui passent par les parties prenantes critiques de la filiale instruite (§3 et §6 du dossier de filiale).
- Le vocabulaire du cours de ce matin : appréciation, évaluation, traitement, risque résiduel, registre.

Ce qu'il faut savoir avant l'exercice

Un quart d'heure de cadrage, sur deux notions que le cours a nommées sans les outiller.

La matrice de cotation, d'abord. Le problème qu'elle traite est un problème d'accord, pas de calcul : quand cinq personnes examinent le même scénario, elles produisent cinq jugements, et rien ne permet de les additionner. Une **matrice de cotation** est une grille à deux axes, la gravité d'un côté, la vraisemblance de l'autre, dont chaque case

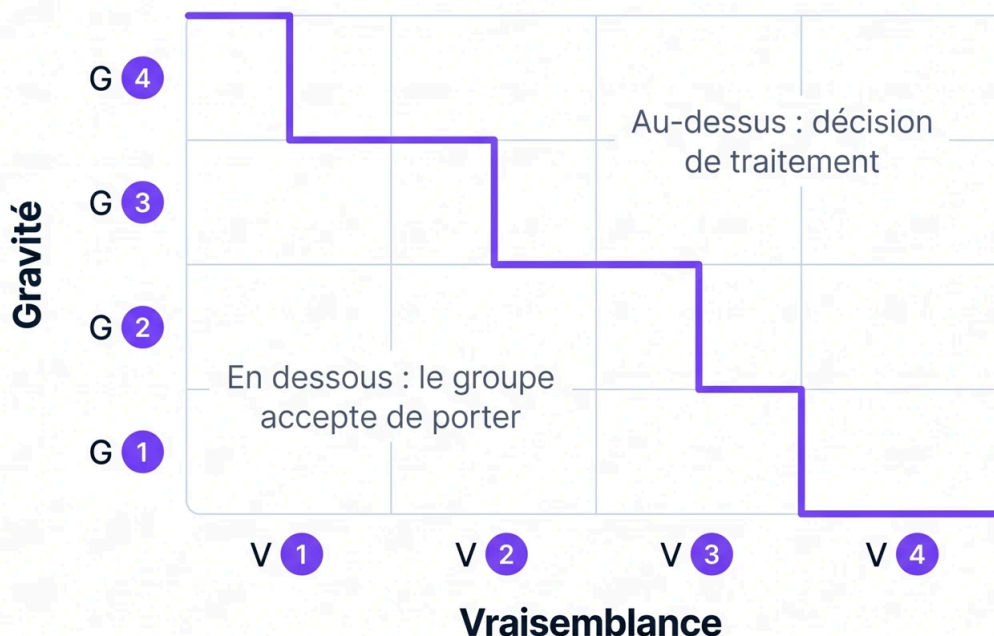
porte un niveau de risque convenu à l'avance. Sa mécanique tient en trois temps : on cote le scénario sur chaque axe séparément, on lit la case au croisement, et le niveau qui s'y trouve devient la position du risque dans le portefeuille. L'intérêt n'est pas la précision, il est ailleurs : la matrice force à séparer deux questions que la discussion mélange toujours, « à quel point ce serait grave » et « à quel point c'est probable ». La plupart des désaccords en atelier viennent de deux personnes qui répondent à des questions différentes en croyant se contredire.

Ce que la matrice ne fait pas mérite d'être dit aussi nettement. Elle ne calcule rien : elle applique une convention que quelqu'un a écrite, et deux organisations peuvent placer le même scénario à deux niveaux différents sans qu'aucune ait tort. Elle ne remplace pas le jugement, elle l'enregistre et le rend discutable. Et elle ne dit jamais quoi faire : elle dit où se situe le risque, la décision reste entière.

L'outil du groupe propose deux grilles, et le choix entre elles est déjà une décision de méthode. La matrice « 4x4 EBIOS-RM » croise quatre niveaux de conséquence et quatre de vraisemblance ; la matrice « 5x5 ISO-27005 » en propose cinq de chaque. Le nombre pair a une vertu que le nombre impair n'a pas : il n'offre pas de milieu. Sur une échelle à cinq niveaux, un atelier indécis cote systématiquement au centre, et le portefeuille finit avec tous ses risques au même endroit, ce qui ne hiérarchise plus rien. Le groupe MERIDIAN travaille en 4x4, cohérent avec les échelles à quatre niveaux justifiées en séance 5.

La ligne d'acceptation, ensuite, et c'est la notion la plus politique de la journée. Le problème : une fois les risques cotés, rien ne dit encore lesquels sont tolérables. Une **ligne d'acceptation** est la frontière, tracée sur la matrice, qui sépare les niveaux que l'organisation accepte de porter de ceux qu'elle refuse. Sa mécanique est simple, ses conséquences ne le sont pas : chaque risque au-dessus de la ligne appelle une décision de traitement, chaque risque en dessous peut rester tel quel, et déplacer la ligne d'une case déplace le budget de sécurité de l'année.

Matrice de Risques : Évaluation et Traitement

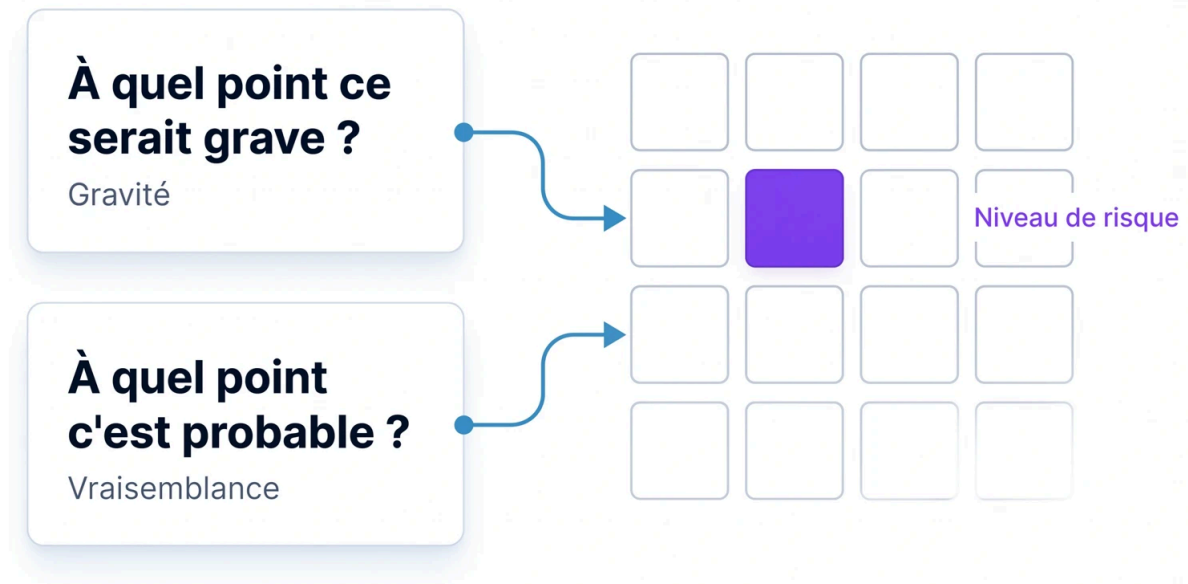


Retenir qui la trace, car c'est le cœur de la gouvernance vue en séance 1. La ligne d'acceptation traduit l'appétence au risque, et l'appétence n'appartient pas au RSSI. Un RSSI qui fixe seul la ligne prend la place de la direction, et le jour de l'incident il portera seul une décision qu'il n'avait pas la légitimité de prendre. Le rôle du RSSI est de préparer, d'éclairer, de proposer, et d'obtenir une décision écrite. Les classes d'acceptation du guide, rappelées ce matin, donnent le vocabulaire de cette décision : acceptable en l'état, tolérable sous contrôle, inacceptable.

Un mot enfin sur les **trois manipulations** à savoir reconnaître, parce qu'elles seront tentées. La première consiste à coter la vraisemblance à la baisse parce que le traitement coûterait cher : la conclusion précède l'analyse, et la cotation devient une justification. La deuxième consiste à découper un gros risque en plusieurs petits, dont aucun ne franchit la ligne : le risque n'a pas diminué, il a été morcelé. La troisième consiste à coter le risque résiduel avant d'avoir décidé des mesures, ce qui revient à mesurer l'effet d'un traitement qui n'existe pas encore. Les trois se repèrent en demandant une chose : montre-moi ce sur quoi tu t'appuies pour cette note.



Exercice 1 : coter quatre scénarios du groupe (15 minutes)



Mise en situation

Le RSSI Groupe prépare le comité de sécurité du groupe. Quatre scénarios issus des ateliers doivent y être présentés cotés, et la Directrice Générale a prévenu qu'elle ne veut pas d'un tableau de couleurs, mais d'une phrase de justification par note. Les quatre scénarios sont ceux du groupe ; celui qui concerne la filiale instruite se retrouvera dans le registre cet après-midi.

#	Scénario de risque	Ce que les ateliers ont établi
A	Un attaquant lucratif atteint la disponibilité des données de soins en passant par l'identifiant partagé de l'éditeur du SIH en télémaintenance	Compte à privilèges partagé, sans traçabilité individuelle ; la filiale Santé porte des activités de soins
B	Un attaquant compromet le poste d'un administrateur du pôle Éducation & Territoires et accède aux données administratives de Territoires	Annuaire d'identités commun au pôle, comptes d'administration partagés entre les deux équipes, données personnelles d'utilisateurs ; le projet de connexion aux bases de Territoires est refusé, non déployé
C	Une mise à jour piégée appliquée par la TMA du WMS fait entrer un code malveillant chez Logistique	Rapproché du modèle NotPetya par la mise à jour d'un tiers ; la TMA applique les siennes la nuit, sans validation ; chaîne d'approvisionnement logicielle
D	Un agent interne exfiltre par erreur un fichier de données personnelles vers un service en ligne non validé	Pas de politique d'usage des services externes ; volumétrie limitée, une filiale

Consignes

Coter les quatre scénarios du tableau sur les deux axes, la gravité puis la vraisemblance, avec les échelles G1 à G4 et V1 à V4 du D5 telles quelles, puis lire leur niveau sur la matrice 4x4. Chaque note tient en une phrase qui renvoie à un niveau nommé de l'échelle et à un signal : un écart constaté à l'audit, une pratique observée, un incident public comparable. Le mot « important » sans référence à l'échelle ne vaut rien. Pour le scénario qui a fait le plus hésiter, dire ce qui ferait changer la note : c'est la question que posera le comité.

À produire : les quatre scénarios cotés sur les deux axes, leur niveau lu sur la matrice, une phrase de justification par note, et deux lignes sur le scénario le plus discuté.

Méthode de travail

Coter la gravité avant la vraisemblance, systématiquement, et sans regarder l'autre axe. C'est une discipline d'atelier, pas une coquetterie : la gravité se juge sur l'atteinte à la mission, et savoir qu'un scénario est probable pousse insensiblement à le trouver plus grave.

✓ Exercice 2 : la ligne d'acceptation, et qui la trace (10 minutes)

Mise en situation

Le RSSI Groupe présente sa matrice au comité. Le Directeur de la Logistique propose de placer la ligne d'acceptation de sorte que le scénario C tombe juste en dessous : « ce sont des mises à jour de notre prestataire de maintenance historique, on ne va pas bloquer la production pour ça ». La Directrice Générale demande l'avis du RSSI avant de trancher.

Consignes

La Directrice Générale attend l'avis du RSSI Groupe avant de trancher. Dire où placer la ligne d'acceptation et sur quelle base, en s'appuyant sur les classes d'acceptation du guide rappelées ce matin plutôt que sur l'intuition. Répondre ensuite au comité en trois phrases : ce que la ligne proposée par la Logistique impliquerait concrètement, ce que le RSSI recommande, et ce qu'il demande par écrit. Nommer enfin qui signe cette décision chez MERIDIAN, avec la répartition des rôles de la séance 1, et dire pourquoi ce n'est pas le RSSI.

À produire : la position de la ligne et sa base, la réponse au comité en trois phrases, et l'instance qui signe, avec la raison.

Ce que l'exercice teste

La capacité à défendre une position sans confisquer la décision. Les deux erreurs symétriques sont de céder en silence, ce qui fabrique une acceptation que personne n'a signée, et de trancher à la place de la direction, ce qui met le RSSI en position intenable.

✓ Exercice 3 : choisir et défendre une option de traitement (20 minutes)

Mise en situation

Les quatre scénarios sont cotés et la ligne est arrêtée. Pour chaque risque au-dessus, il faut une décision, un porteur et une échéance. Le Directeur Financier assistera à la séance et posera la même question à chaque ligne : combien, et pourquoi maintenant.

Consignes

Pour chacun des quatre scénarios, arrêter une option parmi réduire, accepter, éviter, transférer, justifiée en une phrase ; au moins une des quatre n'est pas « réduire », faute de quoi les autres familles n'ont pas été examinées. Chaque réduction porte sa mesure, son porteur nommé et son échéance : une mesure sans porteur est un souhait. Sur le scénario A, dire ce que couvrirait réellement l'assurance cyber proposée et ce qu'elle ne couvre pas. Sur le scénario D, écrire l'acceptation en bonne et due forme : le niveau qui la signe, ce qu'elle contient, l'échéance de son réexamen.

À produire : quatre décisions justifiées, les mesures de réduction avec porteur et échéance, la portée réelle de l'assurance sur A, et l'acceptation formelle de D.

Méthode de travail

Formuler chaque décision comme elle sera lue par un tiers dans deux ans, sans son auteur dans la pièce pour l'expliquer. Le test : la phrase dit-elle qui a décidé, quoi, pourquoi et jusqu'à quand ?



Corrigés et critères d'évaluation – cliquer pour révéler